Bsc Software Engineering B Group 6 zkpm-threat-model

Owner: Keith Tetteh Yaotey
Reviewer: Sedoame Kofi Ahorlu
Contributors: Prince Lateef Abdul Rahman, Bright Kportiklah, Stedan Yaw Boah Ampofo, Prince Opoku Owusu, Cyril Prince Agbeve
Date Generated: Sun Nov 01 2026

Executive Summary

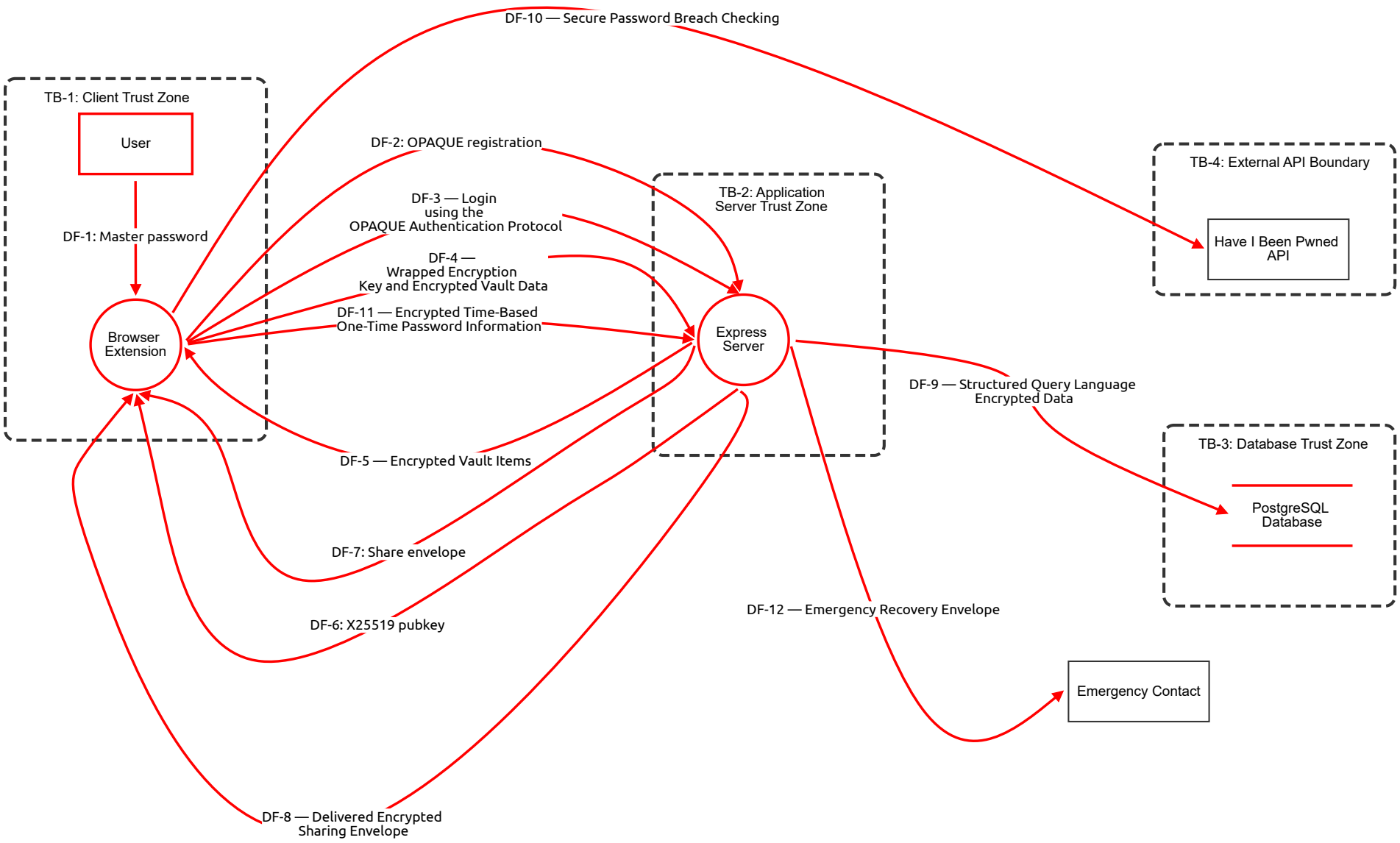
High level system description

Project 6: Zero-Knowledge Password Manager — Week 1 threat model

Summary

Total Threats	21
Total Mitigated	0
Total Open	21
Open / Critical Severity	5
Open / High Severity	8
Open / Medium Severity	6
Open / Low Severity	2

Project 6: Zero-Knowledge Password Manager — Week 1 threat model diagram



Project 6: Zero-Knowledge Password Manager — Week 1 threat model diagram

User (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
24	T-20 Weak Master Password	Elevation of privilege	High	Open		The user chooses a weak master password, allowing an attacker to brute-force the Argon2id derivation and gain access to the entire vault.	Enforce a strict password strength meter during registration and use high-memory Argon2id parameters.

Have I Been Pwned API (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Emergency Contact (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Express Server (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
25	T-21 Server Dependency Exploit	Elevation of privilege	High	Open		An attacker exploits a known vulnerability in an unpatched Node.js or Express dependency to gain unauthorized control over the server process.	Run npm audit in CI, keep dependencies updated, and run the server as a non-root user in Docker.

Browser Extension (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
23	T-14 Phishing Through Browser Frame Impersonation	Elevation of privilege	Critical	Open		An attacker creates a fraudulent webpage or embedded browser frame that imitates a trusted website, attempting to trick the password manager into automatically filling stored login credentials into an unauthorized website.	Verify the exact website origin before automatically filling passwords, including the communication scheme, hostname, and port number. Reject unauthorized embedded frames and require additional user confirmation when necessary.

PostgreSQL Database (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
26	T-22 Database Storage Exhaustion	Denial of service	Medium	Open		An attacker or buggy client fills the database with massive amounts of ciphertext, exhausting disk space and causing a system outage.	Implement strict per-user storage quotas, maximum upload sizes, and database disk-space monitoring.

DF-4 — Wrapped Encryption Key and Encrypted Vault Data (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
17	T-12 Encrypted Vault Synchronization Flooding	Denial of service	High	Open		An attacker repeatedly uploads extremely large encrypted data files to the synchronization service, exhausting server storage, bandwidth, or processing resources.	Enforce maximum request body sizes, user storage quotas, upload limits, and request rate limiting to prevent excessive resource consumption.

DF-1: Master password (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
12	T-07 Master Password Theft	Information disclosure	Critical	Open		A malicious script attempts to capture the user's master password when it is entered into the browser extension, potentially exposing access to the entire password vault.	Use isolated execution environments provided by Manifest Version 3 browser extensions and enforce a strict Content Security Policy to reduce unauthorized script execution.

DF-9 — Structured Query Language Encrypted Data (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	T-03 Encrypted Vault Data Modification	Tampering	Critical	Open		An attacker deliberately changes individual bits of encrypted password vault information stored in the PostgreSQL database, potentially corrupting the stored data.	Use the Extended ChaCha20 stream cipher with Poly1305 message authentication to detect unauthorized modifications to encrypted information.
13	T-08 Database and Server Log Information Theft	Information disclosure	Critical	Open		An attacker gains unauthorized access to the PostgreSQL database and server logs, copying stored encrypted vault information and potentially sensitive account metadata.	Implement a zero-knowledge security architecture in which vault information is encrypted on the user's device and the server never receives the master password, plaintext vault contents, or decryption keys.
19	T-15 Unauthorized Access to Another User's Vault	Elevation of privilege	High	Open		An authenticated attacker manipulates password vault record identifiers to access encrypted information belonging to another user because the server fails to verify record ownership.	Use parameterized Structured Query Language statements and enforce server-side ownership verification using the authenticated user's unique identifier for every vault operation.

DF-5 — Encrypted Vault Items (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
22	T-18 Encrypted Password Vault Rollback Attack	Tampering	High	Open		A compromised server returns an outdated but correctly encrypted version of a user's password vault, potentially restoring old passwords or outdated security settings without the user's knowledge.	Include a version number in the Authenticated Encryption with Associated Data metadata and compare it against a trusted version record to detect attempts to restore outdated vault information.

DF-12 — Emergency Recovery Envelope (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	T-04 Emergency Recovery Timer Manipulation	Tampering	Medium	Open		A malicious administrator changes the waiting period for emergency account recovery to allow encrypted recovery information to be released earlier than authorized.	Use cryptographically signed timestamps and a server-controlled state machine to enforce the correct emergency recovery waiting period.
11	T-06 Denial of Emergency Recovery Activity	Repudiation	Low	Open		An emergency contact performs an account recovery action but later denies having requested or completed that action.	Maintain tamper-evident audit logs and use authenticated digital signatures to provide reliable evidence of emergency recovery actions.
18	T-13 Unauthorized Emergency Recovery Access	Elevation of privilege	High	Open		An attacker exploits weaknesses in the emergency recovery process to bypass the required waiting period and gain access to recovery information before authorization is granted.	Enforce emergency recovery rules on the server using atomic state transitions and database transactions so that recovery requests cannot bypass required authorization checks or waiting periods.

DF-10 — Secure Password Breach Checking (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
14	T-09 — Password Hash Disclosure to Have I Been Pwned	Information disclosure	Critical	Open		The browser extension accidentally transmits the complete Secure Hash Algorithm 1 password hash to the Have I Been Pwned service, unnecessarily exposing information about the user's password.	Use the Have I Been Pwned range application programming interface with the k-anonymity technique. Send only the first five hexadecimal characters of the password hash and perform the remaining comparison locally on the user's device.

DF-7: Share envelope (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	T-05 Denial of Password Sharing Activity	Repudiation	Low	Open		A user shares an encrypted password or vault item with another user but later denies performing the sharing operation.	Require users to digitally sign password-sharing transactions and maintain tamper-resistant records of sharing activities.

DF-2: OPAQUE registration (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
21	T-17 Authentication Registration Replay Attack	Spoofing	Medium	Open		An attacker captures previously transmitted registration messages and attempts to send them again to the server to impersonate a legitimate registration request or interfere with account creation.	Implement server-side replay protection for the OPAQUE registration process, including authenticated registration sessions, prevention of unauthorized registration record replacement, and rejection of duplicate or invalid requests.

DF-8 — Delivered Encrypted Sharing Envelope (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
20	T-16 Modification of Encrypted Sharing Information	Tampering	Medium	Open		An attacker intercepts and modifies an encrypted sharing envelope while it is being delivered from the server to the intended recipient, potentially corrupting or manipulating the shared information.	Protect the encrypted sharing envelope using Authenticated Encryption with Associated Data and verify its authentication tag before accepting or decrypting the information.

DF-6: X25519 pubkey (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	T-02 Public Key Impersonation	Spoofing	High	Open		An attacker replaces a legitimate user's Curve25519 public key with a fraudulent key, potentially allowing the attacker to receive encrypted information intended for another user.	Use cryptographic digital signatures to verify the authenticity and ownership of public keys before sharing encrypted information.

DF-11 — Encrypted Time-Based One-Time Password Information (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
15	T-10 One-Time Password Secret Leakage	Information disclosure	Medium	Open		A secret key used to generate time-based one-time authentication passwords is accidentally transmitted or stored without encryption, potentially allowing an attacker to generate valid authentication codes.	Encrypt each time-based one-time password secret using its dedicated vault item encryption key before sending it to the server.

DF-3 — Login using the OPAQUE Authentication Protocol (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	T-01 — Man-in-the-Middle Attack	Spoofing	Medium	Open		An attacker intercepts communication between the browser extension and the server and attempts to impersonate the legitimate server during the OPAQUE authentication process.	Enforce Transport Layer Security version 1.3 and use the OPAQUE password-authenticated key exchange protocol with proper server authentication.
16	T-11 Authentication Service Flooding	Denial of service	High	Open		An attacker sends an excessive number of authentication requests to the server, consuming computing resources and preventing legitimate users from signing into their accounts.	Implement request rate limiting based on users' Internet Protocol addresses and individual accounts, together with request timeouts and resource limits.